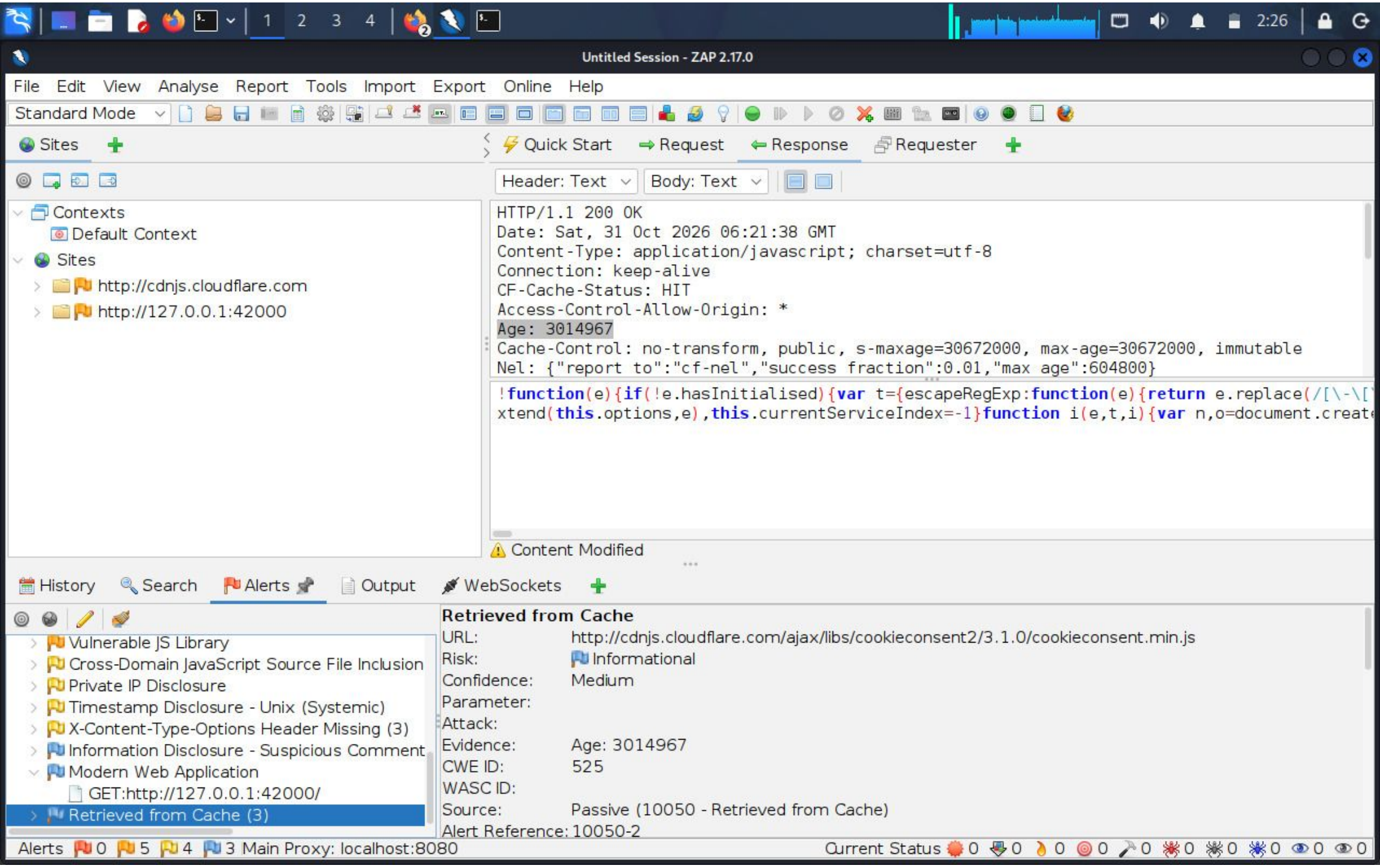
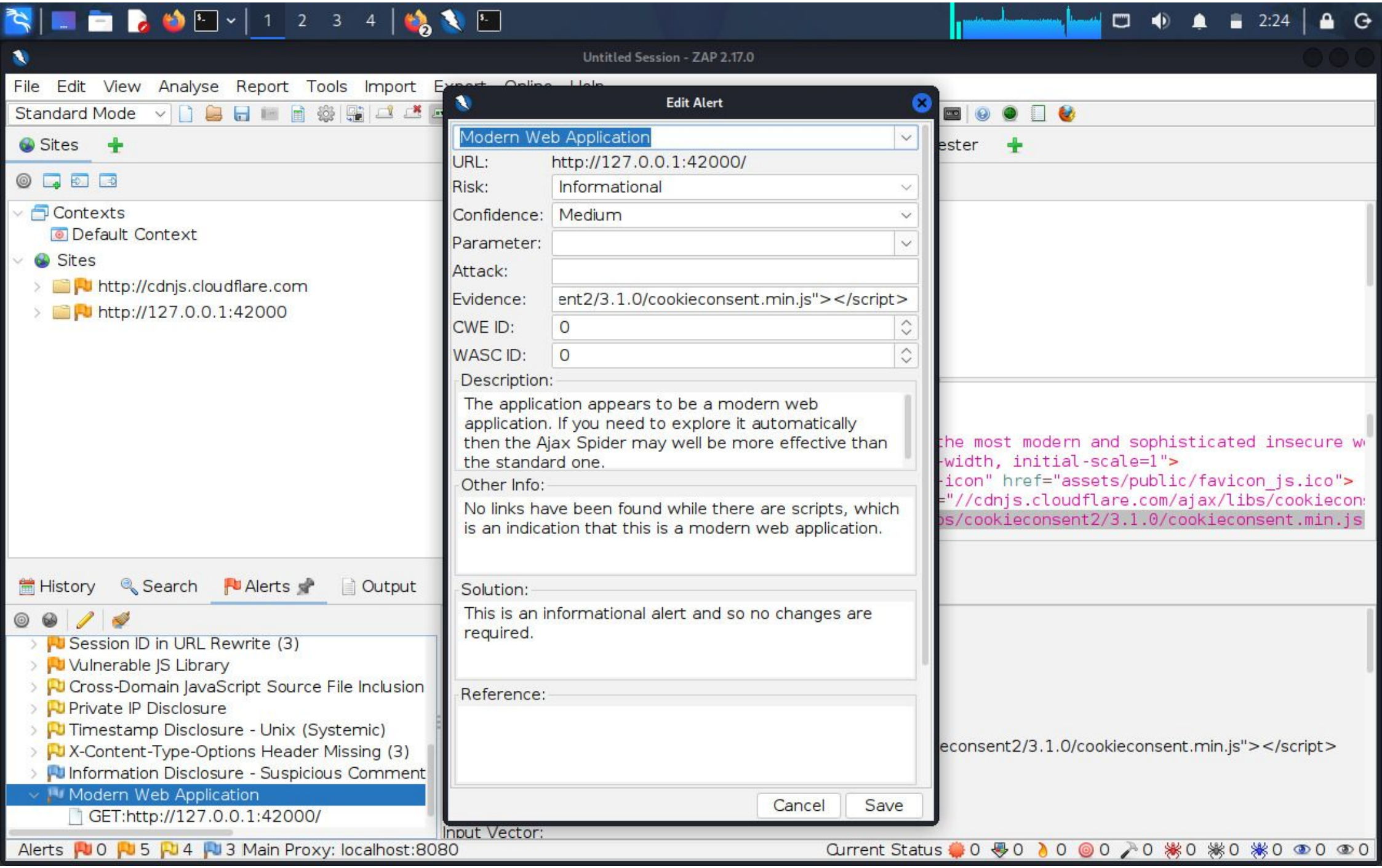
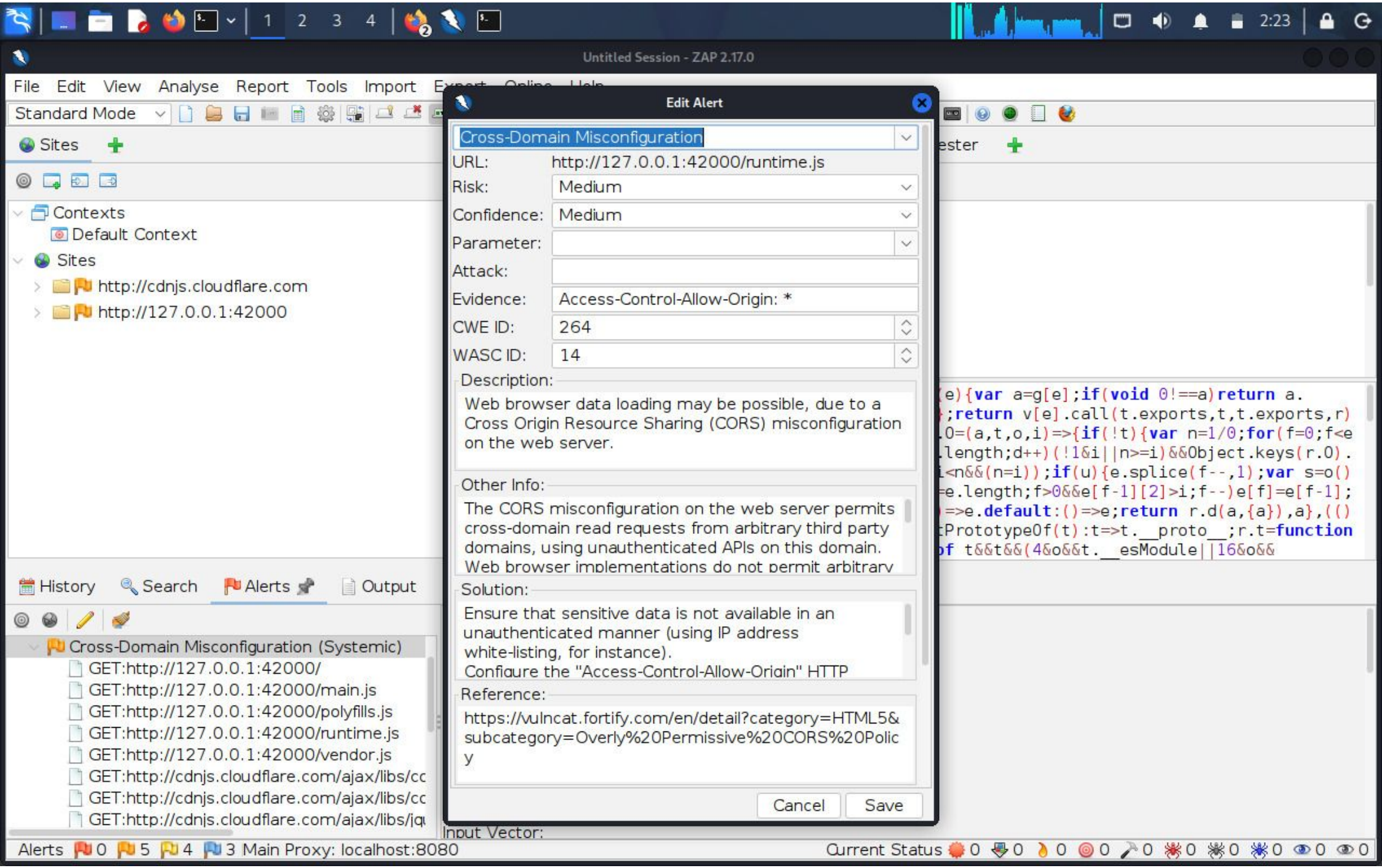
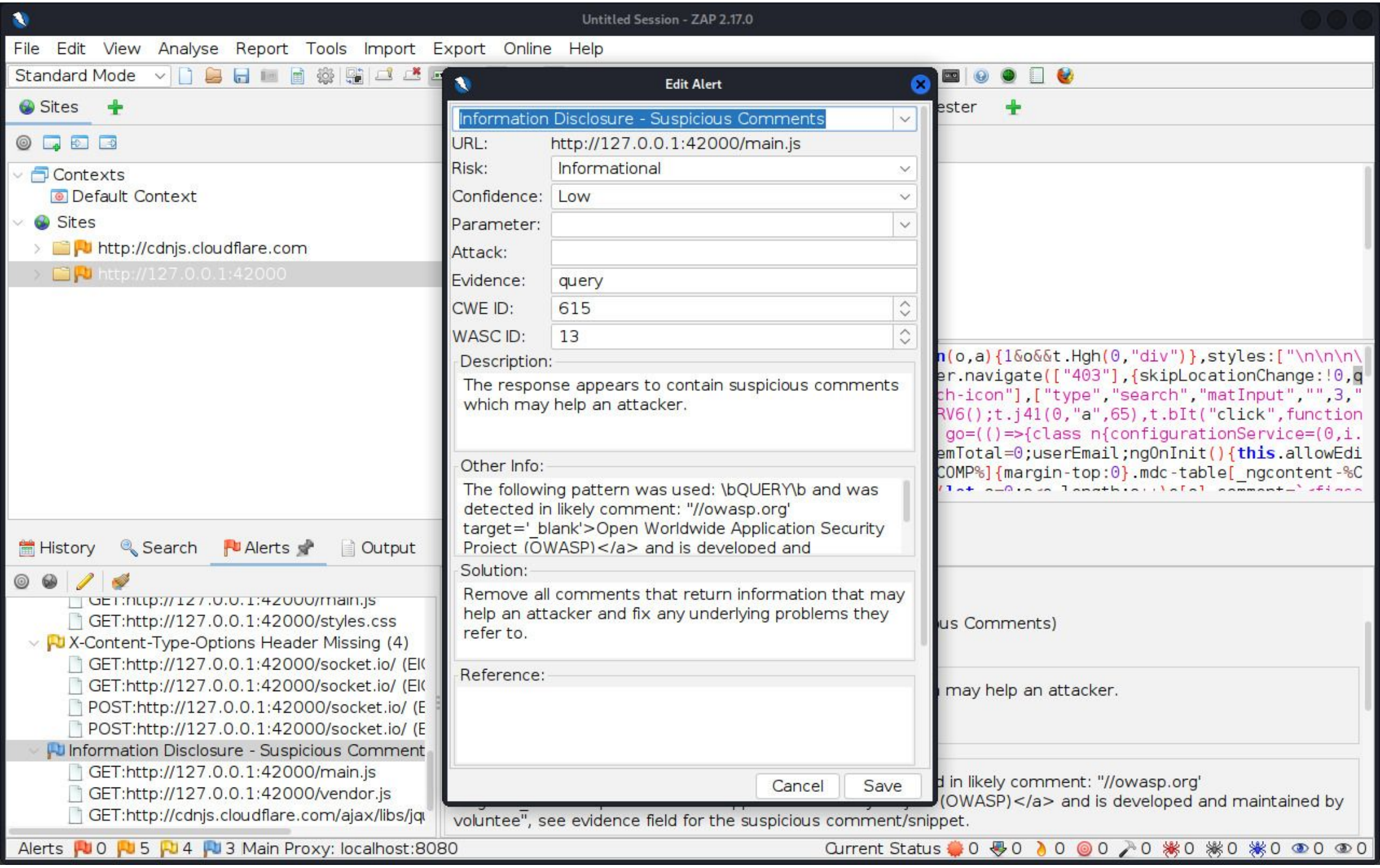
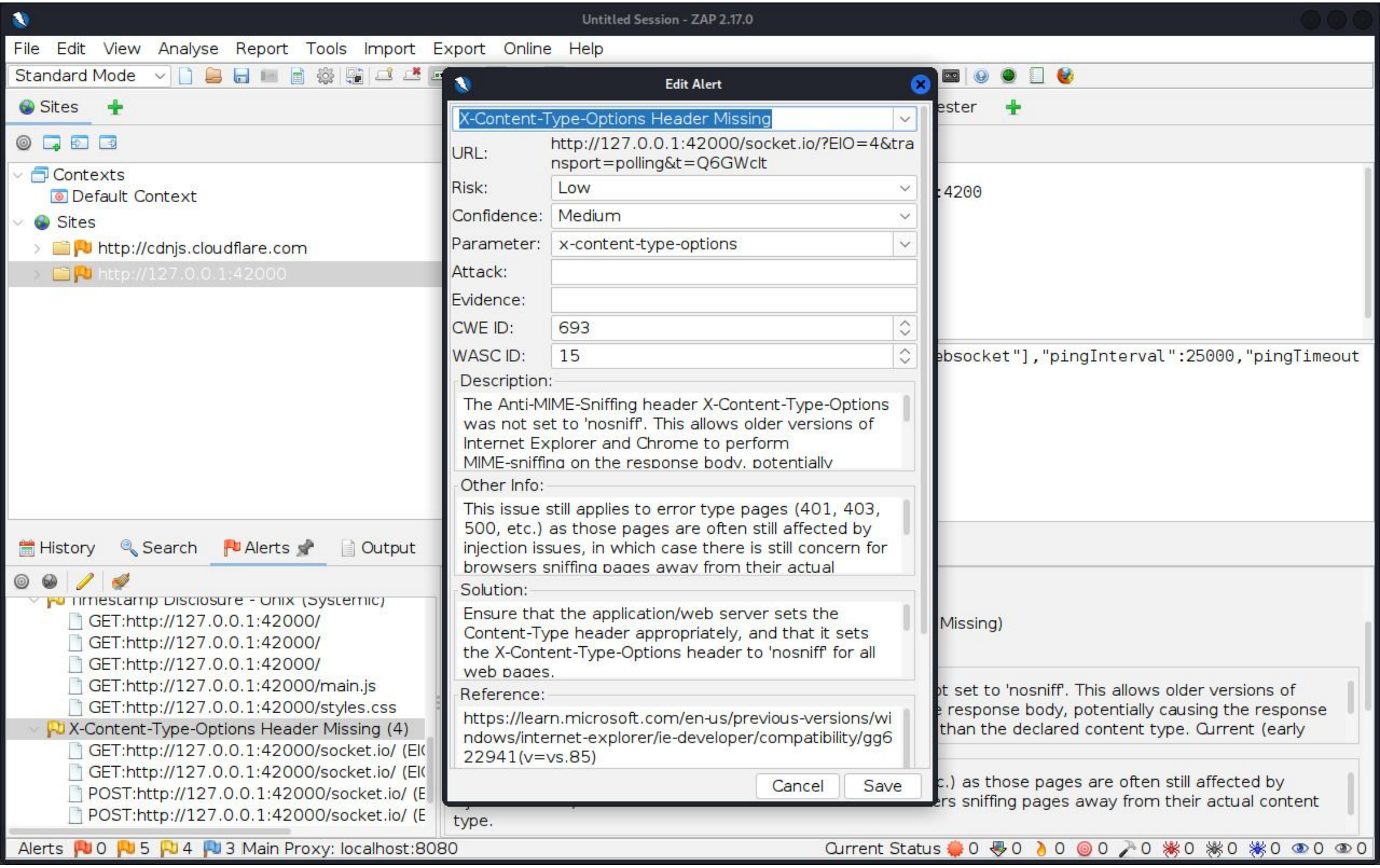
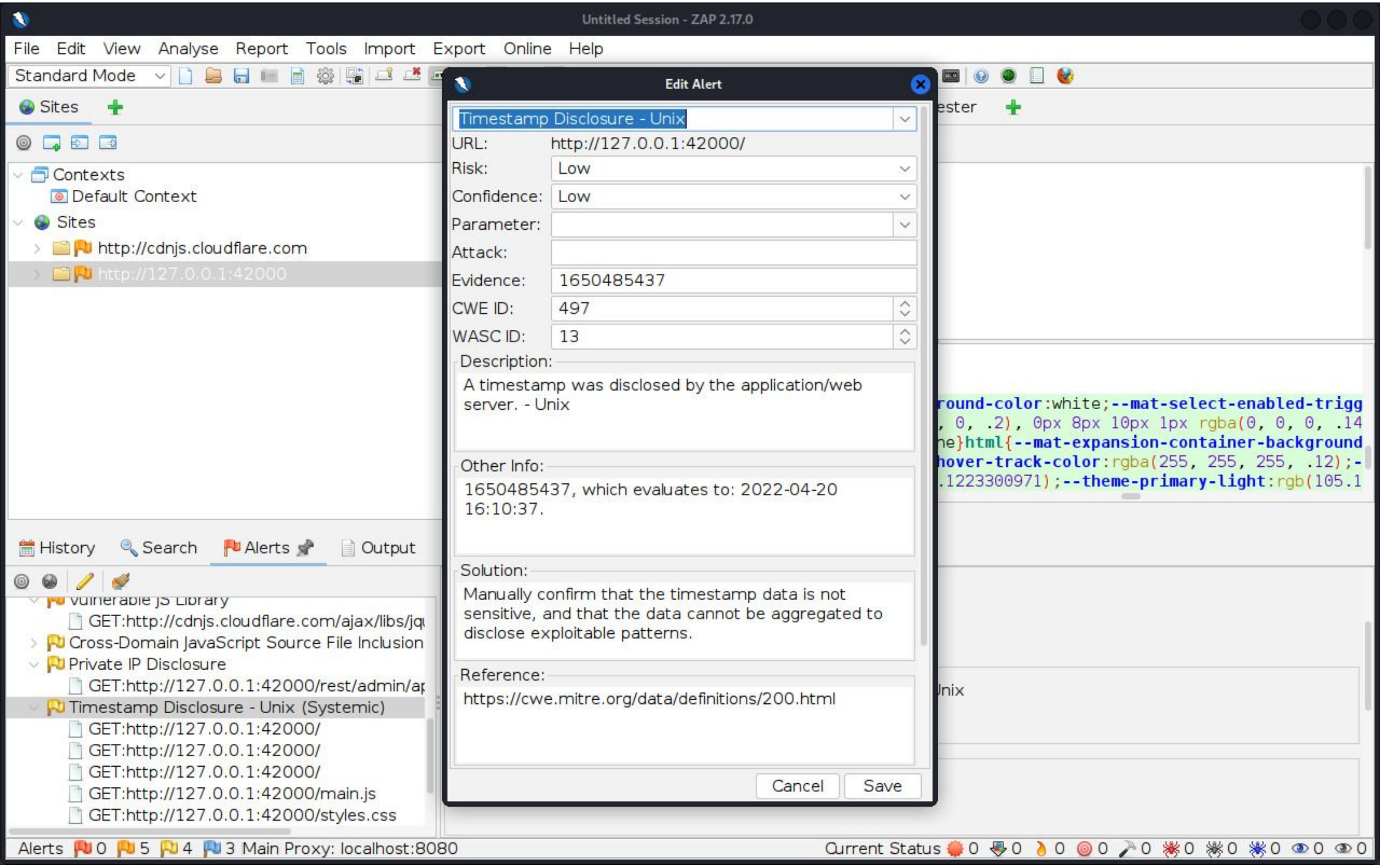

Untitled Session - ZAP 2.17.0
File Edit View Analyse Report Tools Import Export Online Help
Standard Mode
Sites
Quick Start
Request
Response
Requester
Header: Text
Body: Text
Contexts
Default Context
Sites
http://cdnjs.cloudflare.com
http://127.0.0.1:42000
HTTP/1.1 200 OK
Date: Sat, 31 Oct 2026 06:21:38 GMT
Content-Type: application/javascript; charset=utf-8
Connection: keep-alive
CF-Cache-Status: HIT
Access-Control-Allow-Origin: *
Age: 3014967
Cache-Control: no-transform, public, s-maxage=30672000, max-age=30672000, immutable
Nel: {"report to":"cf-nel","success fraction":0.01,"max age":604800}
!function(e){if(!e.hasInitialised){var t={escapeRegExp:function(e){return e.replace(/[\-\[
xtend(this.options,e),this.currentServiceIndex=-1}function i(e,t,i){var n,o=document.creat
Content Modified
History
Search
Alerts
Output
WebSockets
Vulnerable JS Library
Cross-Domain JavaScript Source File Inclusion
Private IP Disclosure
Timestamp Disclosure - Unix (Systemic)
X-Content-Type-Options Header Missing (3)
Information Disclosure - Suspicious Comment
Modern Web Application
GET:http://127.0.0.1:42000/
Retrieved from Cache (3)
Retrieved from Cache
URL: http://cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.js
Risk: Informational
Confidence: Medium
Parameter:
Attack:
Evidence: Age: 3014967
CWE ID: 525
WASC ID:
Source: Passive (10050 - Retrieved from Cache)
Alert Reference: 10050-2
Alerts 0 5 4 3 Main Proxy: localhost:8080
Current Status 0 0 0 0 0 0 0 0 0 0

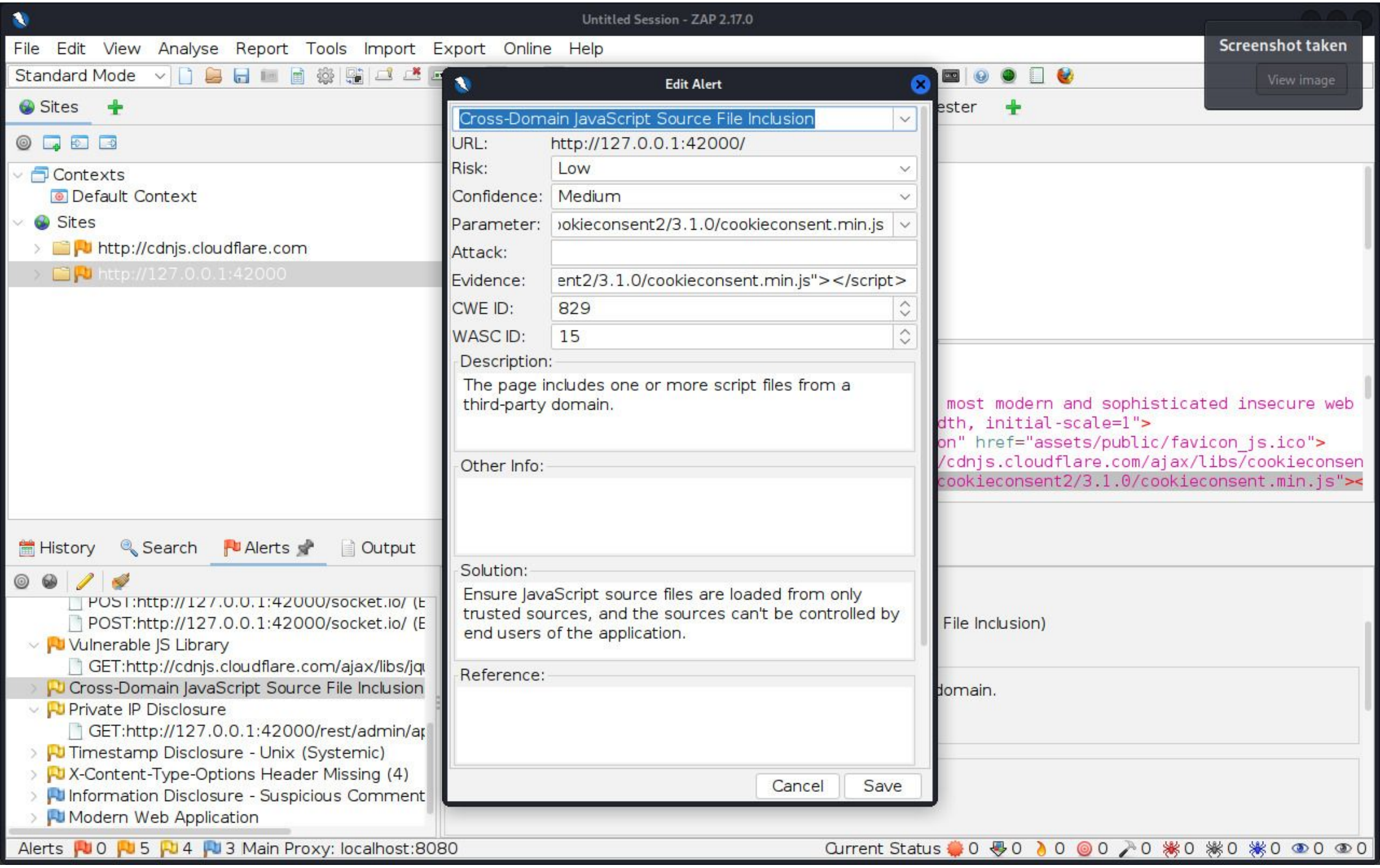

Untitled Session - ZAP 2.17.0
File Edit View Analyse Report Tools Import
Standard Mode
Sites
Contexts
Default Context
Sites
http://cdnjs.cloudflare.com
http://127.0.0.1:42000
History Search Alerts Output
Session ID in URL Rewrite (3)
Vulnerable JS Library
Cross-Domain JavaScript Source File Inclusion
Private IP Disclosure
Timestamp Disclosure - Unix (Systemic)
X-Content-Type-Options Header Missing (3)
Information Disclosure - Suspicious Comment
Modern Web Application
GET:http://127.0.0.1:42000/
Edit Alert
Modern Web Application
URL: http://127.0.0.1:42000/
Risk: Informational
Confidence: Medium
Parameter:
Attack:
Evidence: ent2/3.1.0/cookieconsent.min.js"></script>
CWE ID: 0
WASC ID: 0
Description:
The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.
Other Info:
No links have been found while there are scripts, which is an indication that this is a modern web application.
Solution:
This is an informational alert and so no changes are required.
Reference:
Cancel
Save
Input Vector:
Alerts 0 5 4 3 Main Proxy: localhost:8080
Current Status 0 0 0 0 0 0 0 0 0 0 0

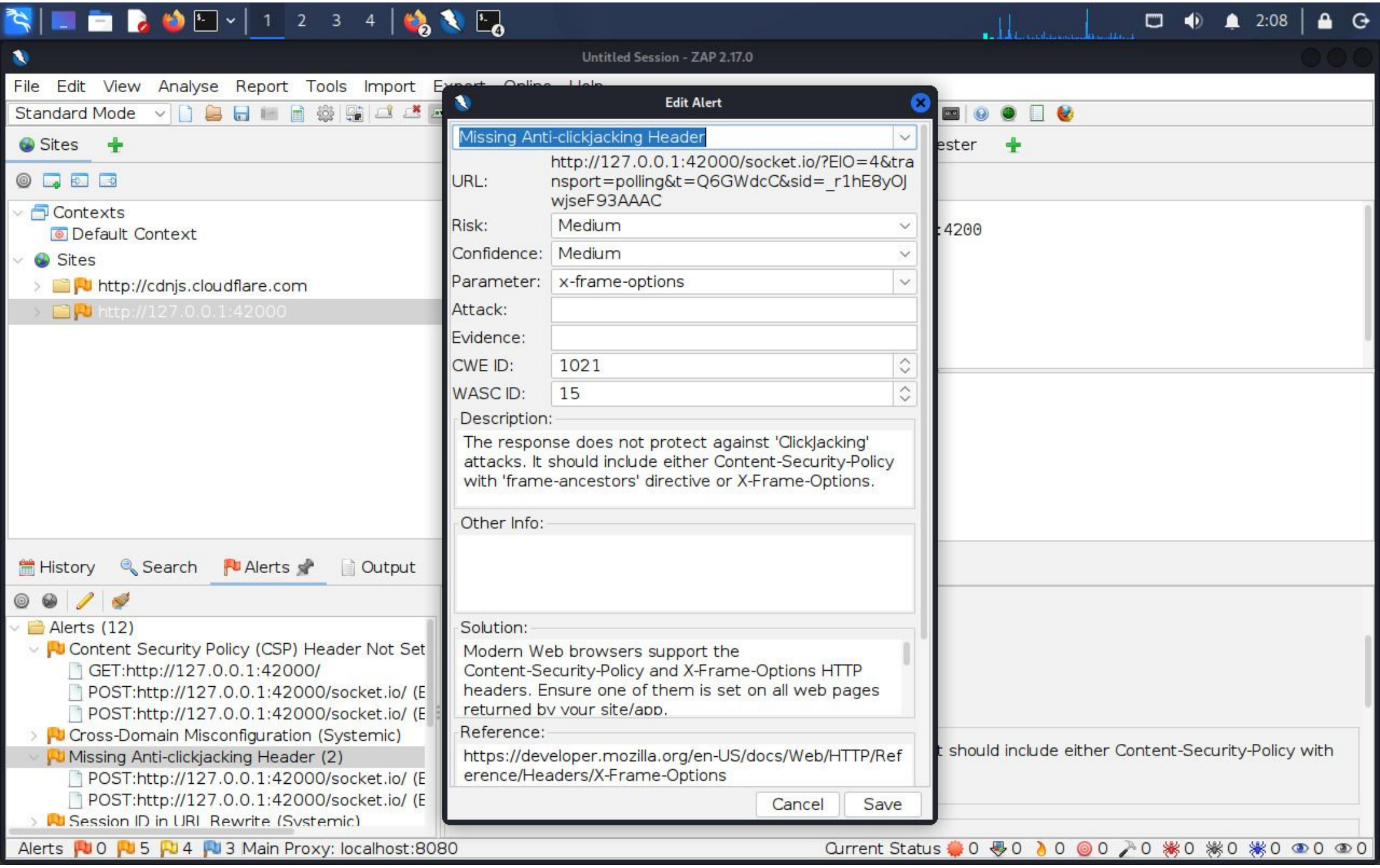

Untitled Session - ZAP 2.17.0
File Edit View Analyse Report Tools Import
Standard Mode
Sites
Contexts
Default Context
Sites
http://cdnjs.cloudflare.com
http://127.0.0.1:42000
History Search Alerts Output
Cross-Domain Misconfiguration (Systemic)
GET:http://127.0.0.1:42000/
GET:http://127.0.0.1:42000/main.js
GET:http://127.0.0.1:42000/polyfills.js
GET:http://127.0.0.1:42000/runtime.js
GET:http://127.0.0.1:42000/vendor.js
GET:http://cdnjs.cloudflare.com/ajax/libs/cc
GET:http://cdnjs.cloudflare.com/ajax/libs/cc
GET:http://cdnjs.cloudflare.com/ajax/libs/jq
Edit Alert
Cross-Domain Misconfiguration
URL: http://127.0.0.1:42000/runtime.js
Risk: Medium
Confidence: Medium
Parameter:
Attack:
Evidence: Access-Control-Allow-Origin: *
CWE ID: 264
WASC ID: 14
Description:
Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.
Other Info:
The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary
Solution:
Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance).
Configure the "Access-Control-Allow-Origin" HTTP
Reference:
https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy
Cancel
Save
Input Vector:
Alerts 0 5 4 3 Main Proxy: localhost:8080
Current Status 0 0 0 0 0 0 0 0 0 0

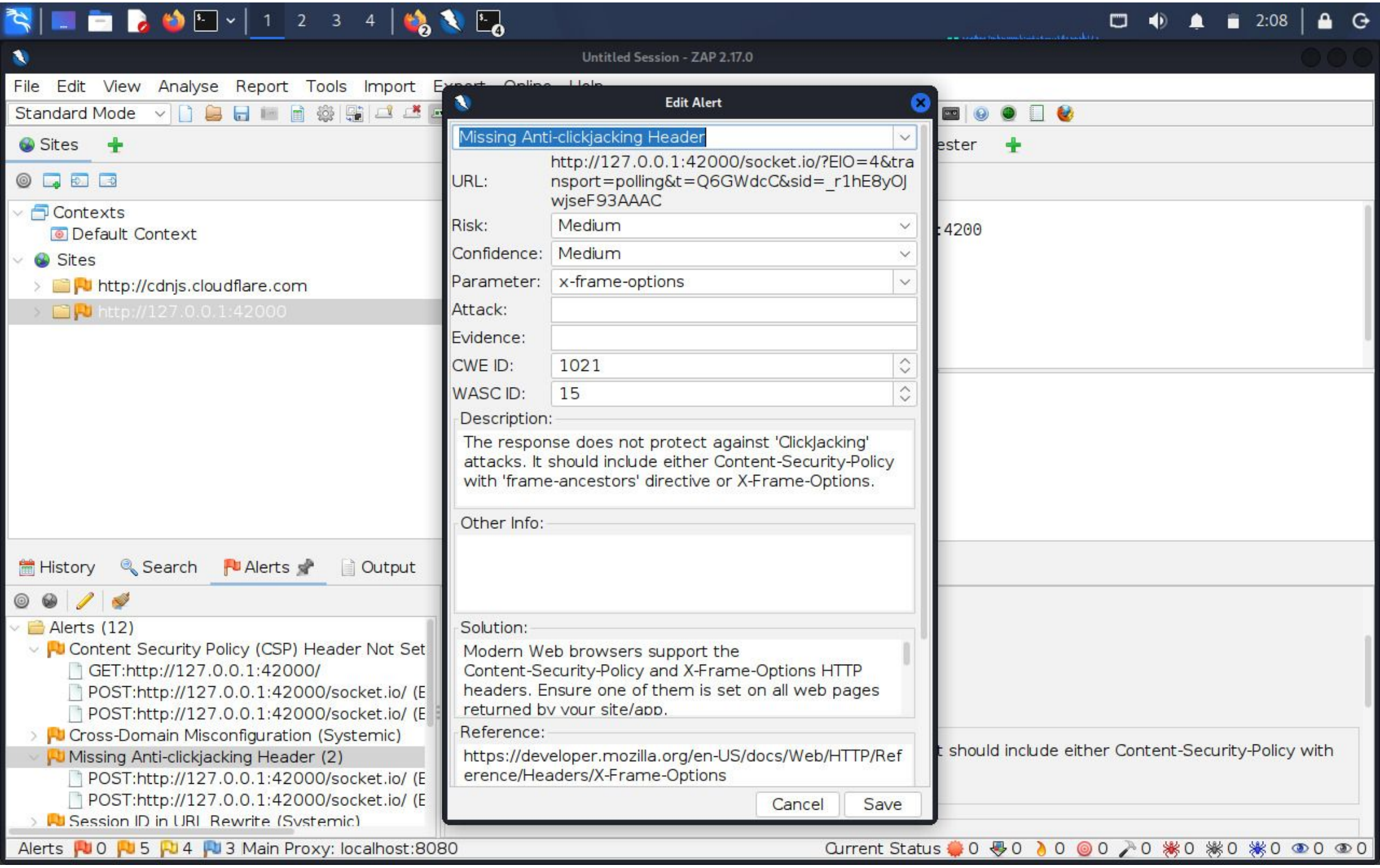

Untitled Session - ZAP 2.17.0
File Edit View Analyse Report Tools Import Export Online Help
Standard Mode
Sites
Contexts
Default Context
Sites
http://cdnjs.cloudflare.com
http://127.0.0.1:42000
History Search Alerts Output
GET:http://127.0.0.1:42000/styles.css
X-Content-Type-Options Header Missing (4)
GET:http://127.0.0.1:42000/socket.io/ (El
GET:http://127.0.0.1:42000/socket.io/ (El
POST:http://127.0.0.1:42000/socket.io/ (E
POST:http://127.0.0.1:42000/socket.io/ (E
Information Disclosure - Suspicious Comment
GET:http://127.0.0.1:42000/main.js
GET:http://127.0.0.1:42000/vendor.js
GET:http://cdnjs.cloudflare.com/ajax/libs/jq
Edit Alert
Information Disclosure - Suspicious Comments
URL: http://127.0.0.1:42000/main.js
Risk: Informational
Confidence: Low
Parameter:
Attack:
Evidence: query
CWE ID: 615
WASC ID: 13
Description:
The response appears to contain suspicious comments which may help an attacker.
Other Info:
The following pattern was used: \bQUERY\b and was detected in likely comment: "//owasp.org' target='_blank'>Open Worldwide Application Security Project (OWASP) and is developed and
Solution:
Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.
Reference:
Cancel
Save
Alerts 0 5 4 3 Main Proxy: localhost:8080
Current Status 0 0 0 0 0 0 0 0 0 0 0

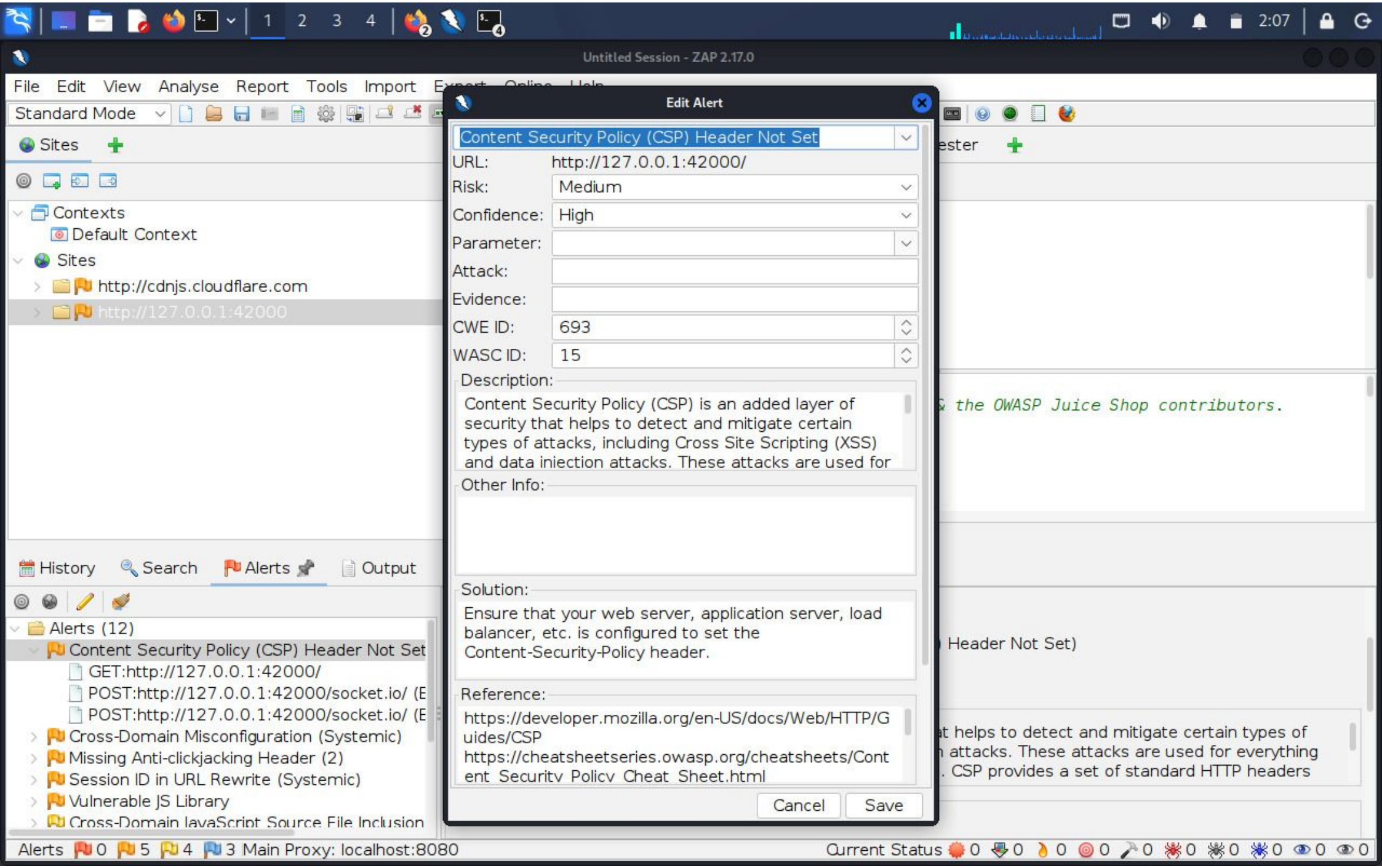

Untitled Session - ZAP 2.17.0
File Edit View Analyse Report Tools Import Export Online Help
Standard Mode
Sites
Contexts
Default Context
Sites
http://cdnjs.cloudflare.com
http://127.0.0.1:42000
History Search Alerts Output
Timestamp Disclosure - Unix (Systemic)
GET:http://127.0.0.1:42000/
GET:http://127.0.0.1:42000/
GET:http://127.0.0.1:42000/
GET:http://127.0.0.1:42000/main.js
GET:http://127.0.0.1:42000/styles.css
X-Content-Type-Options Header Missing (4)
GET:http://127.0.0.1:42000/socket.io/ (El
GET:http://127.0.0.1:42000/socket.io/ (El
POST:http://127.0.0.1:42000/socket.io/ (E
POST:http://127.0.0.1:42000/socket.io/ (E
Alerts 0 5 4 3 Main Proxy: localhost:8080
Current Status 0 0 0 0 0 0 0 0 0 0 0
Edit Alert
X-Content-Type-Options Header Missing
URL: http://127.0.0.1:42000/socket.io/?EIO=4&transport=polling&t=Q6GWclt
Risk: Low
Confidence: Medium
Parameter: x-content-type-options
Attack:
Evidence:
CWE ID: 693
WASC ID: 15
Description:
The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially
Other Info:
This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual
Solution:
Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages.
Reference:
https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85)
Cancel
Save
:4200
ebsocket"],"pingInterval":25000,"pingTimeout
Missing)
t set to 'nosniff'. This allows older versions of
e response body, potentially causing the response
than the declared content type. Current (early
c.) as those pages are often still affected by
rs sniffing pages away from their actual content
type.

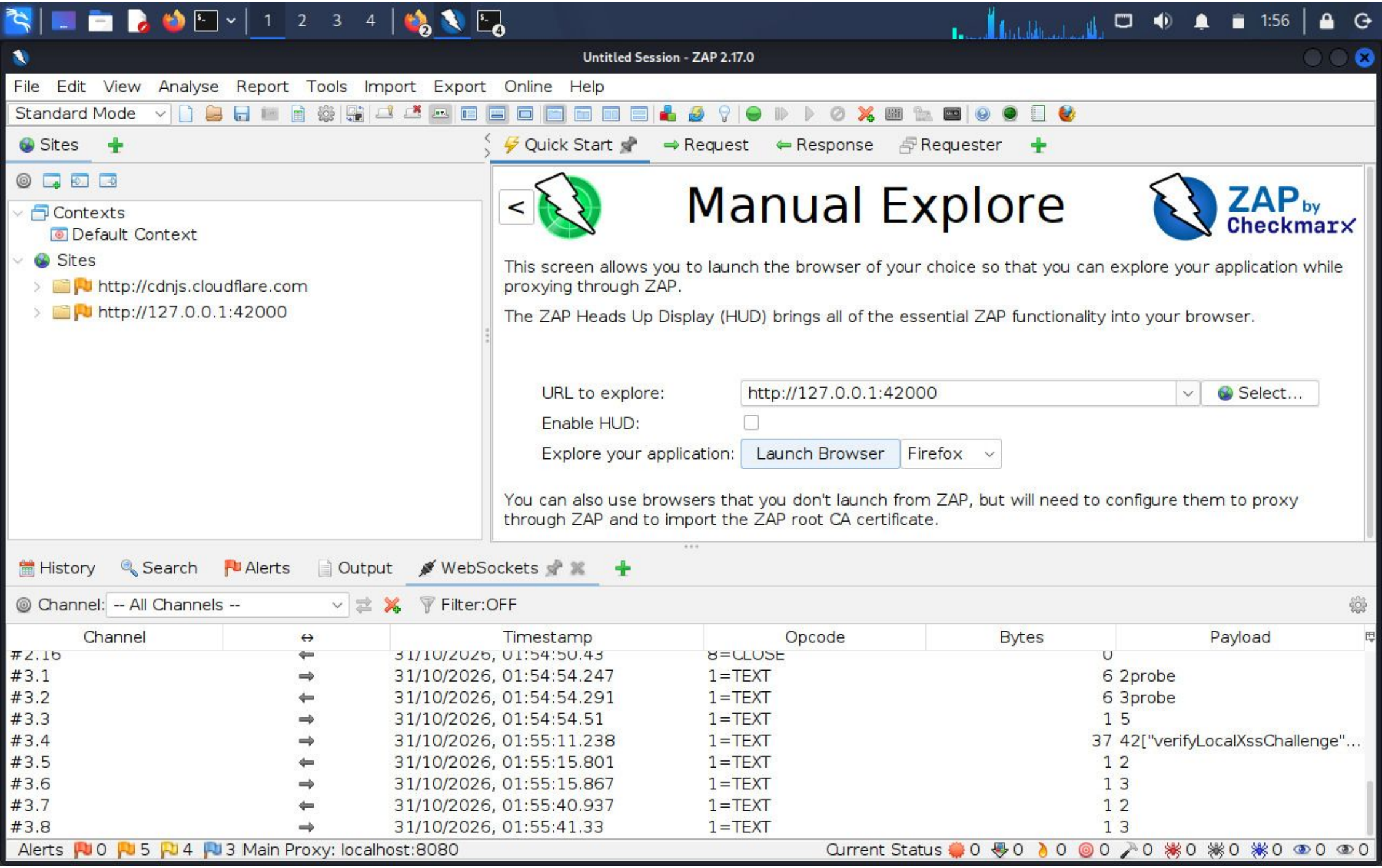

Untitled Session - ZAP 2.17.0
File Edit View Analyse Report Tools Import Export Online Help
Standard Mode
Sites
Contexts
Default Context
Sites
http://cdnjs.cloudflare.com
http://127.0.0.1:42000
History Search Alerts Output
Vulnerable JS Library
GET:http://cdnjs.cloudflare.com/ajax/libs/jq
Cross-Domain JavaScript Source File Inclusion
Private IP Disclosure
GET:http://127.0.0.1:42000/rest/admin/ap
Timestamp Disclosure - Unix (Systemic)
GET:http://127.0.0.1:42000/
GET:http://127.0.0.1:42000/
GET:http://127.0.0.1:42000/
GET:http://127.0.0.1:42000/main.js
GET:http://127.0.0.1:42000/styles.css
Alerts 0 5 4 3 Main Proxy: localhost:8080
Current Status 0 0 0 0 0 0 0 0 0 0 0
Edit Alert
Timestamp Disclosure - Unix
URL: http://127.0.0.1:42000/
Risk: Low
Confidence: Low
Parameter:
Attack:
Evidence: 1650485437
CWE ID: 497
WASC ID: 13
Description:
A timestamp was disclosed by the application/web server. - Unix
Other Info:
1650485437, which evaluates to: 2022-04-20 16:10:37.
Solution:
Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.
Reference:
https://cwe.mitre.org/data/definitions/200.html
Cancel
Save


Untitled Session - ZAP 2.17.0
File Edit View Analyse Report Tools Import Export Online Help
Standard Mode
Screenshot taken
View image
Sites
Contexts
Default Context
Sites
http://cdnjs.cloudflare.com
http://127.0.0.1:42000
Edit Alert
Cross-Domain JavaScript Source File Inclusion
URL: http://127.0.0.1:42000/
Risk: Low
Confidence: Medium
Parameter: ookieconsent2/3.1.0/cookieconsent.min.js
Attack:
Evidence: ent2/3.1.0/cookieconsent.min.js"></script>
CWE ID: 829
WASC ID: 15
Description:
The page includes one or more script files from a third-party domain.
Other Info:
Solution:
Ensure JavaScript source files are loaded from only trusted sources, and the sources can't be controlled by end users of the application.
Reference:
Cancel
Save
most modern and sophisticated insecure web
dth, initial-scale=1">
on" href="assets/public/favicon_js.ico">
/cdnjs.cloudflare.com/ajax/libs/cookieconsen
cookieconsent2/3.1.0/cookieconsent.min.js"><
File Inclusion)
domain.
History
Search
Alerts
Output
POST:http://127.0.0.1:42000/socket.io/ (E
POST:http://127.0.0.1:42000/socket.io/ (E
Vulnerable JS Library
GET:http://cdnjs.cloudflare.com/ajax/libs/jq
Cross-Domain JavaScript Source File Inclusion
Private IP Disclosure
GET:http://127.0.0.1:42000/rest/admin/ap
Timestamp Disclosure - Unix (Systemic)
X-Content-Type-Options Header Missing (4)
Information Disclosure - Suspicious Comment
Modern Web Application
Alerts 0 5 4 3 Main Proxy: localhost:8080
Current Status 0 0 0 0 0 0 0 0 0 0 0


Untitled Session - ZAP 2.17.0
File Edit View Analyse Report Tools Import
Standard Mode
Sites
Contexts
Default Context
Sites
http://cdnjs.cloudflare.com
http://127.0.0.1:42000
History Search Alerts Output
Alerts (12)
Content Security Policy (CSP) Header Not Set
GET:http://127.0.0.1:42000/
POST:http://127.0.0.1:42000/socket.io/ (E
POST:http://127.0.0.1:42000/socket.io/ (E
Cross-Domain Misconfiguration (Systemic)
Missing Anti-clickjacking Header (2)
POST:http://127.0.0.1:42000/socket.io/ (E
POST:http://127.0.0.1:42000/socket.io/ (E
Session ID in URL Rewrite (Systemic)
Alerts 0 5 4 3 Main Proxy: localhost:8080
Current Status 0 0 0 0 0 0 0 0 0 0
Edit Alert
Missing Anti-clickjacking Header
URL: http://127.0.0.1:42000/socket.io/?EIO=4&transport=polling&t=Q6GWdcC&sid=_r1hE8yOJwjseF93AAAC
Risk: Medium
Confidence: Medium
Parameter: x-frame-options
Attack:
Evidence:
CWE ID: 1021
WASC ID: 15
Description:
The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
Other Info:
Solution:
Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app.
Reference:
https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
Cancel
Save
:4200
t should include either Content-Security-Policy with


Untitled Session - ZAP 2.17.0
File Edit View Analyse Report Tools Import
Standard Mode
Sites
Contexts
Default Context
Sites
http://cdnjs.cloudflare.com
http://127.0.0.1:42000
History Search Alerts Output
Alerts (12)
Content Security Policy (CSP) Header Not Set
GET:http://127.0.0.1:42000/
POST:http://127.0.0.1:42000/socket.io/ (E
POST:http://127.0.0.1:42000/socket.io/ (E
Cross-Domain Misconfiguration (Systemic)
Missing Anti-clickjacking Header (2)
POST:http://127.0.0.1:42000/socket.io/ (E
POST:http://127.0.0.1:42000/socket.io/ (E
Session ID in URL Rewrite (Systemic)
Alerts 0 5 4 3 Main Proxy: localhost:8080
Current Status 0 0 0 0 0 0 0 0 0 0
Edit Alert
Missing Anti-clickjacking Header
URL: http://127.0.0.1:42000/socket.io/?EIO=4&transport=polling&t=Q6GWdcC&sid=_r1hE8yOJwjseF93AAAC
Risk: Medium
Confidence: Medium
Parameter: x-frame-options
Attack:
Evidence:
CWE ID: 1021
WASC ID: 15
Description:
The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
Other Info:
Solution:
Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app.
Reference:
https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
Cancel
Save
:4200
t should include either Content-Security-Policy with


Untitled Session - ZAP 2.17.0
File Edit View Analyse Report Tools Import
Standard Mode
Sites
Contexts
Default Context
Sites
http://cdnjs.cloudflare.com
http://127.0.0.1:42000
History Search Alerts Output
Alerts (12)
Content Security Policy (CSP) Header Not Set
GET:http://127.0.0.1:42000/
POST:http://127.0.0.1:42000/socket.io/ (E
POST:http://127.0.0.1:42000/socket.io/ (E
Cross-Domain Misconfiguration (Systemic)
Missing Anti-clickjacking Header (2)
Session ID in URL Rewrite (Systemic)
Vulnerable JS Library
Alerts 0 5 4 3 Main Proxy: localhost:8080
Current Status 0 0 0 0 0 0 0 0 0 0
Edit Alert
Content Security Policy (CSP) Header Not Set
URL: http://127.0.0.1:42000/
Risk: Medium
Confidence: High
Parameter:
Attack:
Evidence:
CWE ID: 693
WASC ID: 15
Description:
Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for
Other Info:
Solution:
Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference:
https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP
https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
Cancel
Save
& the OWASP Juice Shop contributors.
Header Not Set)
t helps to detect and mitigate certain types of
attacks. These attacks are used for everything
. CSP provides a set of standard HTTP headers


Untitled Session - ZAP 2.17.0
File Edit View Analyse Report Tools Import Export Online Help
Standard Mode
Sites
Quick Start
Request
Response
Requester
Contexts
Default Context
Sites
http://cdnjs.cloudflare.com
http://127.0.0.1:42000
Manual Explore
ZAP by Checkmarx
This screen allows you to launch the browser of your choice so that you can explore your application while proxying through ZAP.
The ZAP Heads Up Display (HUD) brings all of the essential ZAP functionality into your browser.
URL to explore:
http://127.0.0.1:42000
Select...
Enable HUD:
Explore your application:
Launch Browser
Firefox
You can also use browsers that you don't launch from ZAP, but will need to configure them to proxy through ZAP and to import the ZAP root CA certificate.
History
Search
Alerts
Output
WebSockets
Channel: -- All Channels --
Filter:OFF
Channel
Timestamp
Opcode
Bytes
Payload
#3.1 31/10/2026, 01:54:54.247 1=TEXT 6 2probe
#3.2 31/10/2026, 01:54:54.291 1=TEXT 6 3probe
#3.3 31/10/2026, 01:54:54.51 1=TEXT 1 5
#3.4 31/10/2026, 01:55:11.238 1=TEXT 37 42["verifyLocalXssChallenge"...
#3.5 31/10/2026, 01:55:15.801 1=TEXT 1 2
#3.6 31/10/2026, 01:55:15.867 1=TEXT 1 3
#3.7 31/10/2026, 01:55:40.937 1=TEXT 1 2
#3.8 31/10/2026, 01:55:41.33 1=TEXT 1 3
Alerts 0 5 4 3 Main Proxy: localhost:8080
Current Status

OWASP Juice Shop

http://127.0.0.1:42000/#/search?q=apple

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

OWASP Juice Shop

apple

Account EN

Search Results - apple



Apple Juice (1000ml)

1.99¤



Apple Pomace

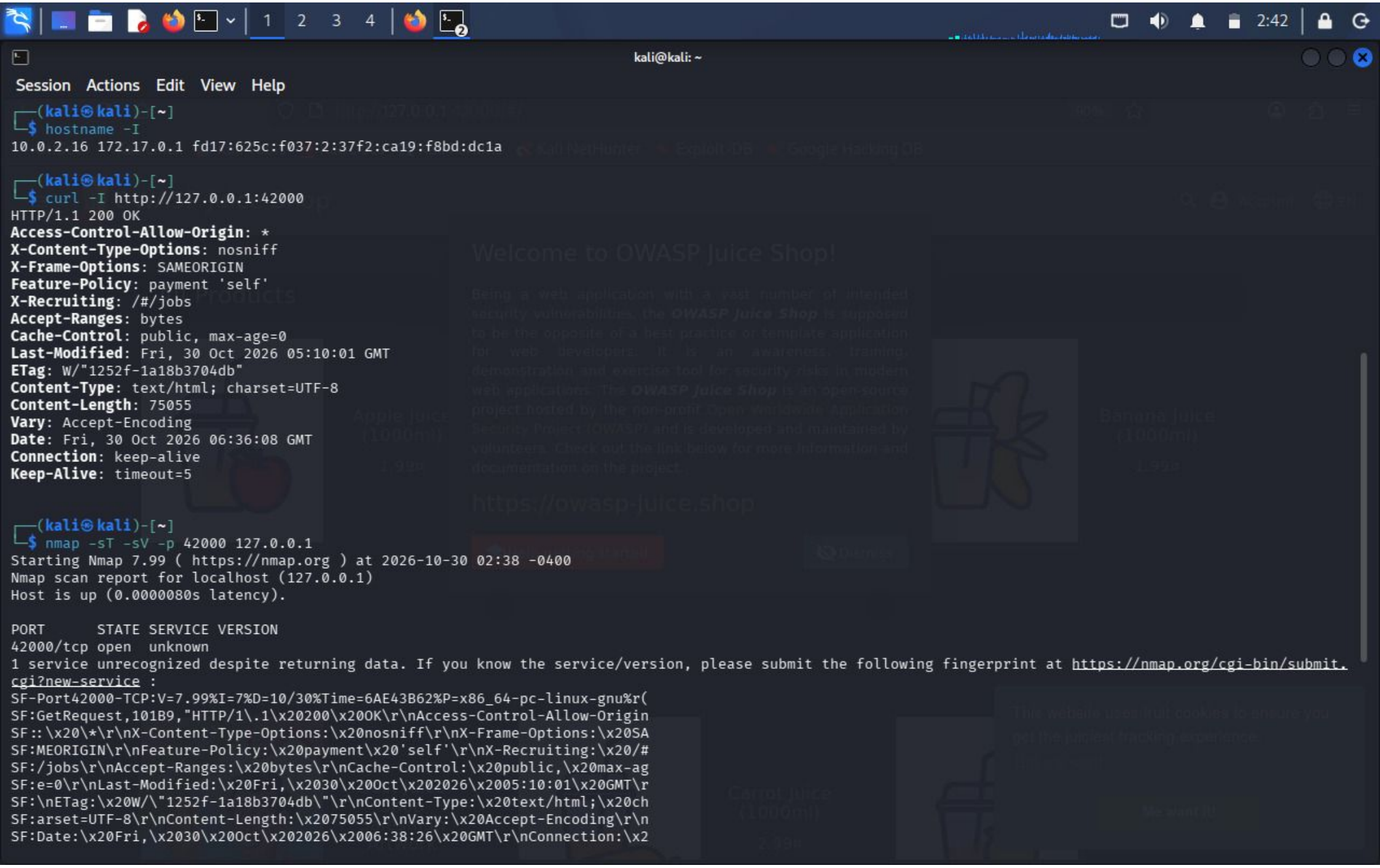
0.89¤

Items per page: 12

This website uses fruit cookies to ensure you get the juiciest tracking experience.

But me wait!

Me want it!


1 2 3 4
2:42
kali@kali: ~
Session Actions Edit View Help
┌──(kali㉿kali)-[~]
└─$ hostname -I
10.0.2.16 172.17.0.1 fd17:625c:f037:2:37f2:ca19:f8bd:dc1a
┌──(kali㉿kali)-[~]
└─$ curl -I http://127.0.0.1:42000
HTTP/1.1 200 OK
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Accept-Ranges: bytes
Cache-Control: public, max-age=0
Last-Modified: Fri, 30 Oct 2026 05:10:01 GMT
ETag: W/"1252f-1a18b3704db"
Content-Type: text/html; charset=UTF-8
Content-Length: 75055
Vary: Accept-Encoding
Date: Fri, 30 Oct 2026 06:36:08 GMT
Connection: keep-alive
Keep-Alive: timeout=5
┌──(kali㉿kali)-[~]
└─$ nmap -sT -sV -p 42000 127.0.0.1
Starting Nmap 7.99 (https://nmap.org) at 2026-10-30 02:38 -0400
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0000080s latency).
PORT STATE SERVICE VERSION
42000/tcp open unknown
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port42000-TCP:V=7.99%I=7%D=10/30%Time=6AE43B62%P=x86_64-pc-linux-gnu%r(
SF:GetRequest,101B9,"HTTP/1\.1\x20200\x20OK\r\nAccess-Control-Allow-Origin
SF::\x20*\r\nX-Content-Type-Options:\x20nosniff\r\nX-Frame-Options:\x20SA
SF:MEORIGIN\r\nFeature-Policy:\x20payment\x20'self'\r\nX-Recruiting:\x20/#
SF:/jobs\r\nAccept-Ranges:\x20bytes\r\nCache-Control:\x20public,\x20max-ag
SF:e=0\r\nLast-Modified:\x20Fri,\x2030\x20Oct\x202026\x2005:10:01\x20GMT\r
SF:\nETag:\x20W/\"1252f-1a18b3704db\"\r\nContent-Type:\x20text/html;\x20ch
SF:arset=UTF-8\r\nContent-Length:\x2075055\r\nVary:\x20Accept-Encoding\r\n
SF:Date:\x20Fri,\x2030\x20Oct\x202026\x2006:38:26\x20GMT\r\nConnection:\x2